Projet de Fin d'Année

Mise en place d'un SIEM Wazuh

Détection d'intrusions et analyse d'alertes
en environnement virtualisé

Présenté par : **Madini machkour**

Encadré par : **M.Madini Machkour**

ISMAGI

Filière : cyber sécurity

Année universitaire 2025 – 2026

Table des matières

1 Introduction **5**
1.1 Organisation du rapport 5

2 Qu'est-ce qu'un SIEM ? Présentation de Wazuh **6**
2.1 Le concept de SIEM 6
2.2 Les quatre briques de Wazuh 6
2.3 Les ports à connaître 7
2.4 Naissance d'une alerte 7

3 Environnement de travail **8**
3.1 Virtualisation 8
3.2 Choix du mode réseau : NAT plutôt que Bridged 8

4 Mise en place du serveur Wazuh **9**
4.1 Installation 9
4.2 Premiers constats 10

5 Déploiement des agents **11**
5.1 Agent Windows 10 11
5.2 Agent Kali Linux (profil Debian) 12
5.3 Validation 12

6 Journal de bord : problèmes rencontrés et solutions **14**
6.1 Leçons tirées 15

7 Simulations d'attaques et détection **16**
7.1 Méthodologie 16
7.2 Attaque 1 : brute force sur comptes Windows 16
7.3 Attaque 2 : brute force SSH sur le serveur Kali 17
7.4 Lecture des fiches agent 18

8 Analyse des alertes : méthode d'un analyste SOC **19**

9 Conclusion et perspectives **20**
9.1 Bilan 20
9.2 Limites 20
9.3 Perspectives 20

A Anti-sèche : commandes utiles **21**

B Glossaire **22**

Table des figures

3.1 Architecture finale du laboratoire (réseau NAT VMnet8) 8

4.1 Tableau de bord Wazuh après installation : vue d'ensemble des alertes des dernières 24 heures 9

5.1 Installation de l'agent Wazuh sur la machine Windows 10 11
5.2 Journal de l'agent Windows : connexion chiffrée (AES) établie avec le serveur 12
5.3 Les deux agents (Windows10 et kalijoker) actifs, version 4.8.2, couverture 100 % 13

7.1 Alertes de règle 60122 « Logon failure - Unknown user or bad password » (niveau 5), avec tactiques et techniques MITRE ATT&CK 17
7.2 Détection de la brute force SSH : règle 2502 niveau 10 (T1110) et règles 5710 (utilisateurs inexistants) 18
7.3 Fiche d'information système de l'agent dans le dashboard 18

Liste des tableaux

2.1 Composants de la plateforme Wazuh 6
2.2 Flux réseau de la plateforme 7

3.1 Machines virtuelles du laboratoire 8

6.1 Journal des incidents du projet 14

8.1 Fiche d'analyse de l'incident « brute force SSH » 19

Chapitre 1

Introduction

Les attaques informatiques ne sont plus l'exception : elles sont la norme. Une entreprise moyenne met plusieurs mois à découvrir qu'elle a été compromise, souvent parce que personne ne surveille réellement ce qui se passe sur ses machines. C'est précisément le rôle d'un SIEM (*Security Information and Event Management*) : centraliser les journaux d'événements, détecter les comportements suspects et alerter les équipes de sécurité.

L'objectif de ce projet de fin d'année était de construire, de bout en bout, une plateforme de détection d'intrusions fonctionnelle autour de la solution open source **Wazuh**, puis de la mettre à l'épreuve en simulant des attaques réelles de type *brute force*. Le périmètre comprend un serveur Wazuh sous Ubuntu, deux machines supervisées (Windows 10 et Kali Linux) et une analyse des alertes produites selon le référentiel MITRE ATT&CK.

Ce rapport raconte l'intégralité de la démarche : le choix de l'architecture, l'installation, mais aussi – et surtout – les nombreux problèmes rencontrés et la manière dont ils ont été résolus. Un tutoriel montre uniquement le chemin qui fonctionne ; un projet réel est fait de détours. J'ai choisi de documenter ces détours honnêtement, car c'est là que se trouve le véritable apprentissage.

1.1 Organisation du rapport

Le chapitre 2 présente le fonctionnement d'un SIEM et de Wazuh. Le chapitre 3 décrit l'environnement technique. Les chapitres 4 et 5 détaillent l'installation du serveur et des agents. Le chapitre 6 constitue le journal de bord des incidents. Les chapitres 7 et 8 présentent les attaques simulées et leur analyse. Le chapitre 9 conclut et ouvre des perspectives.

Chapitre 2

Qu'est-ce qu'un SIEM ? Présentation de Wazuh

2.1 Le concept de SIEM

Un SIEM collecte les journaux d'événements (logs) de toutes les machines d'un parc, les normalise, les corrèle et applique des règles de détection. Lorsqu'une règle correspond à un événement suspect, une **alerte** est générée, classée par niveau de gravité, puis présentée aux analystes dans une interface web.

2.2 Les quatre briques de Wazuh

Wazuh suit une architecture client-serveur que j'ai pu observer concrètement durant le projet :

Table 2.1 – Composants de la plateforme Wazuh

Composant	**Localisation**	**Rôle**
Agent	Machines supervisées	Collecte les logs (événements Windows, auth.log, intégrité des fichiers) et les transmet au serveur
Manager	Serveur Ubuntu	Analyse les logs à l'aide de décodeurs et de règles, génère les alertes
Indexer	Serveur Ubuntu	Base de données (OpenSearch) qui stocke et indexe les alertes
Dashboard	Serveur Ubuntu	Interface web de visualisation et d'investigation

2.3 Les ports à connaître

Table 2.2 – Flux réseau de la plateforme

Port	Protocole	Utilité
1514	TCP	Envoi des événements des agents vers le manager
1515	TCP	Service d'enregistrement (échange de la clé d'agent)
443	HTTPS	Interface web du dashboard
9200	HTTPS	API de l'indexer
55000	HTTPS	API REST du manager

2.4 Naissance d'une alerte

Le cycle de vie d'une alerte, que j'ai vérifié expérimentalement, est le suivant : un événement est écrit dans un log (par exemple un échec de connexion SSH dans `/var/log/auth.log`) ; l'agent le transmet au manager ; le décodeur identifie le programme d'origine (sshd, PAM, Windows...) ; la règle correspondante est appliquée ; si le seuil est atteint, l'alerte est indexée puis affichée dans le dashboard, accompagnée de son mappage MITRE ATT&CK.

Chapitre 3

Environnement de travail

3.1 Virtualisation

L'ensemble du laboratoire repose sur VMware Workstation 17 exécuté sur un ordinateur portable Windows 11 connecté en Wi-Fi. Ce détail apparemment anodin aura une importance considérable dans la suite du projet (chapitre 6).

Table 3.1 – Machines virtuelles du laboratoire

VM	Système	Rôle	Adresse IP
Ubuntu 64-bit	Ubuntu Server 22.04	Serveur Wazuh	192.168.234.10
Windows 10 PFA	Windows 10 Education	Agent supervisé	192.168.234.134
Debian 12 (Kali)	Kali Linux 2026.2	Agent supervisé	192.168.234.128

3.2 Choix du mode réseau : NAT plutôt que Bridged

Mon premier réflexe a été de placer toutes les machines en mode *bridged* afin qu'elles obtiennent des adresses du réseau domestique (192.168.1.x). Ce choix s'est révélé impossible à fiabiliser : une borne Wi-Fi n'accepte que la carte réseau qui s'est authentifiée auprès d'elle (celle de l'hôte), et rejette silencieusement les trames provenant des adresses MAC virtuelles des VMs. Résultat observé : les VMs communiquaient entre elles (commutation locale par VMware) mais aucune ne joignait la passerelle ni Internet.

La solution, déjà éprouvée lors d'un projet précédent avec un pare-feu FortiGate, consiste à utiliser le mode **NAT** de VMware (réseau VMnet8, sous-réseau 192.168.234.0/24). Le trafic sort alors par la pile réseau de l'hôte, ce qui contourne totalement la limitation du Wi-Fi, tout en garantissant une communication stable entre les VMs et depuis l'hôte.

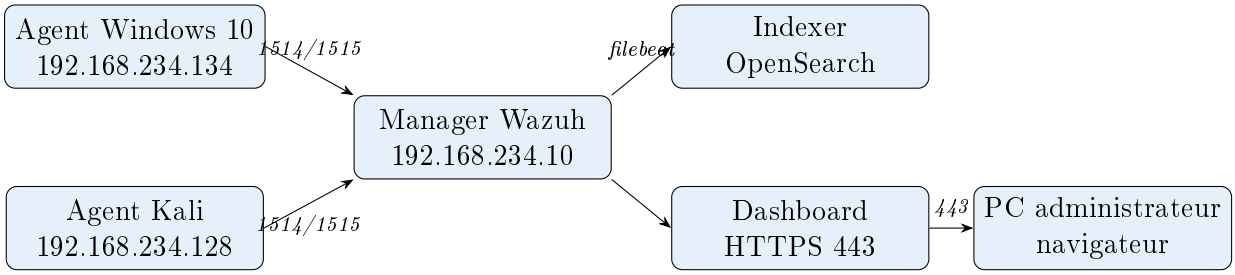


Figure 3.1 – Architecture finale du laboratoire (réseau NAT VMnet8)

Chapitre 4

Mise en place du serveur Wazuh

4.1 Installation

Le serveur a été déployé sur Ubuntu Server 22.04 à l'aide du script officiel, qui installe en une seule fois le manager, l'indexer et le dashboard :

```
curl -sO https://packages.wazuh.com/4.8/wazuh-install.sh
sudo bash ./wazuh-install.sh -a
```

À la fin de l'installation, le script affiche les identifiants générés pour l'interface web. La première connexion s'effectue depuis le navigateur de l'hôte à l'adresse `https://192.168.234.10` (le certificat auto-signé impose d'accepter une exception de sécurité, ce qui est normal en laboratoire).

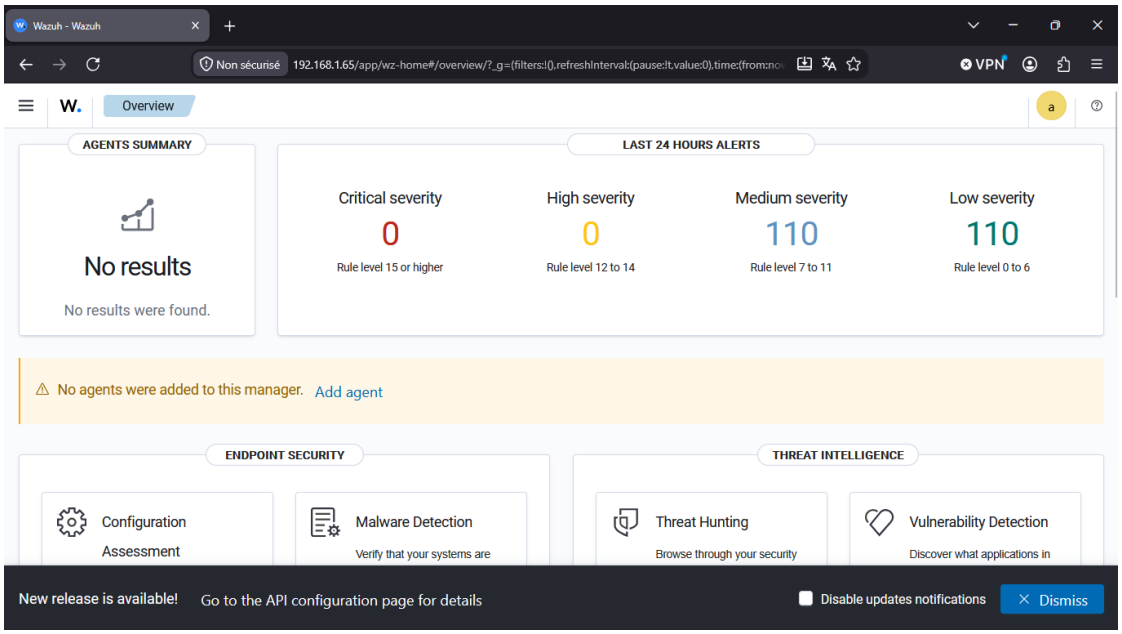


Figure 4.1 – Tableau de bord Wazuh après installation : vue d'ensemble des alertes des dernières 24 heures

4.2 Premiers constats

Dès la mise en service, le serveur produit ses propres alertes de fonctionnement (niveau 3 à 5). La plateforme est saine : il reste à lui donner des yeux, c'est-à-dire des agents.

Chapitre 5

Déploiement des agents

5.1 Agent Windows 10

L'agent Windows a été installé depuis le paquet MSI officiel, en précisant l'adresse du serveur afin que l'enregistrement soit automatique :

```
wazuh-agent-4.8.2-1.msi /q WAZUH_MANAGER="192.168.234.10" ^
WAZUH_REGISTRATION_SERVER="192.168.234.10" WAZUH_AGENT_NAME="Windows10"
```

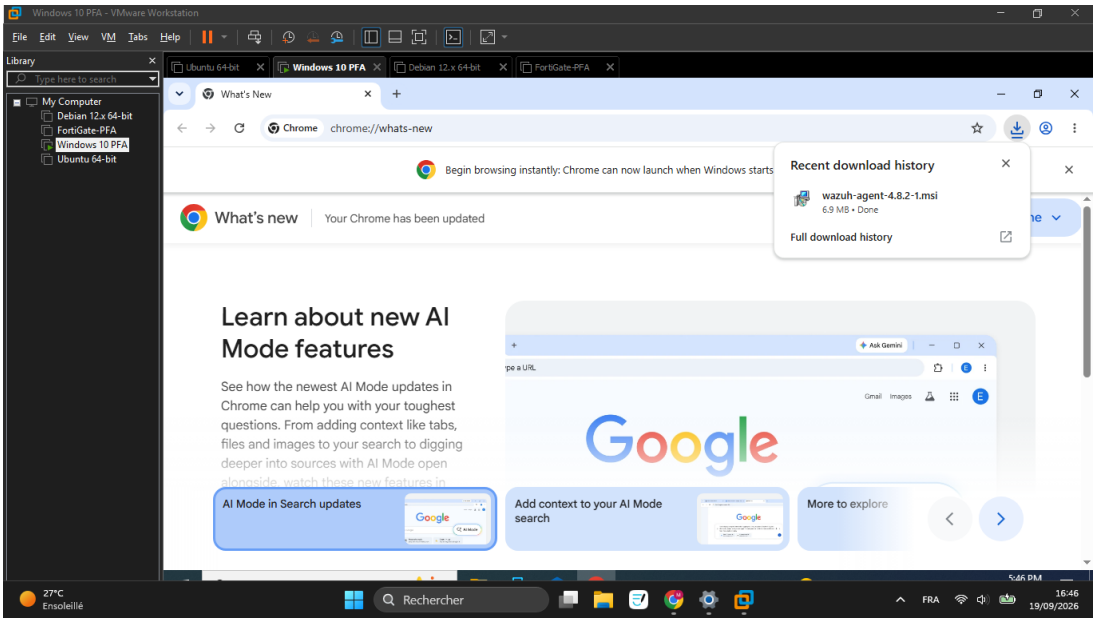


Figure 5.1 – Installation de l'agent Wazuh sur la machine Windows 10

Le service `WazuhSvc` passe à l'état *Running* et le journal de l'agent confirme la connexion au manager sur le port 1514 :

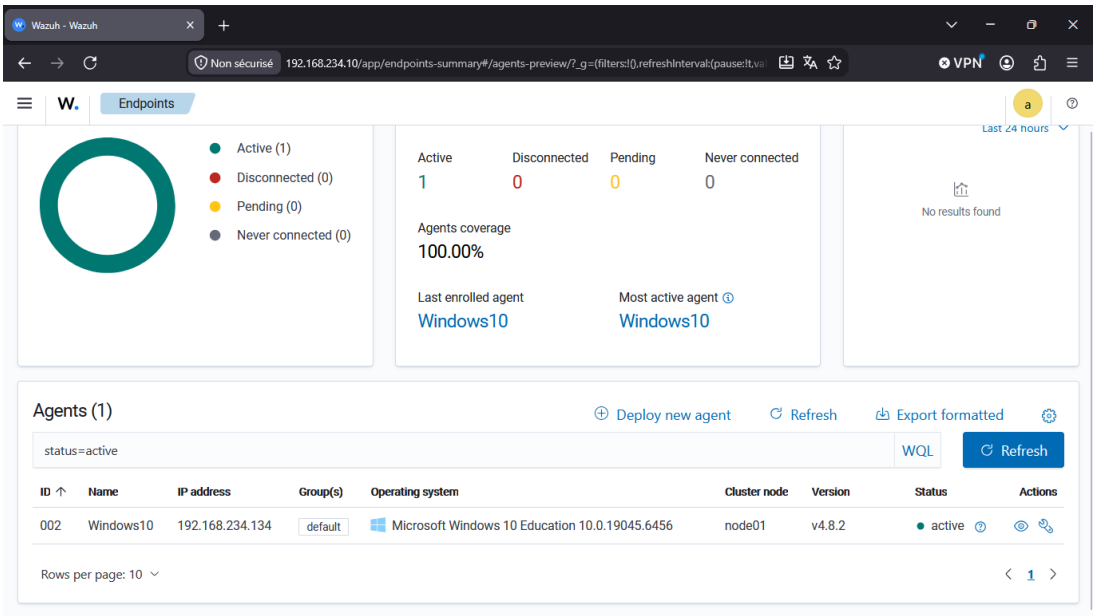


FIGURE 5.2 – Journal de l'agent Windows : connexion chiffrée (AES) établie avec le serveur

5.2 Agent Kali Linux (profil Debian)

Sur Kali, l'installation passe par le dépôt APT officiel :

```
curl -s https://packages.wazuh.com/key/GPG-KEY-WAZUH | gpg --no-default-keyring
    \
  --keyring gnupg-ring:/usr/share/keyrings/wazuh.gpg --import
echo "deb [signed-by=/usr/share/keyrings/wazuh.gpg] \
https://packages.wazuh.com/4.x/apt/ stable main" | tee /etc/apt/sources.list.d/
    wazuh.list
apt update
WAZUH_MANAGER="192.168.234.10" WAZUH_AGENT_NAME="DebianDMZ" apt install wazuh-
    agent -y
```

Un point d'attention important : le dépôt `4.x` fournit la dernière version majeure (4.14 au moment du projet), incompatible avec un serveur en 4.8.2. Un retour arrière contrôlé a donc été nécessaire :

```
apt install wazuh-agent=4.8.2-1 -y --allow-downgrades
```

5.3 Validation

Le dashboard confirme alors la présence des deux agents, avec une couverture de 100 % :

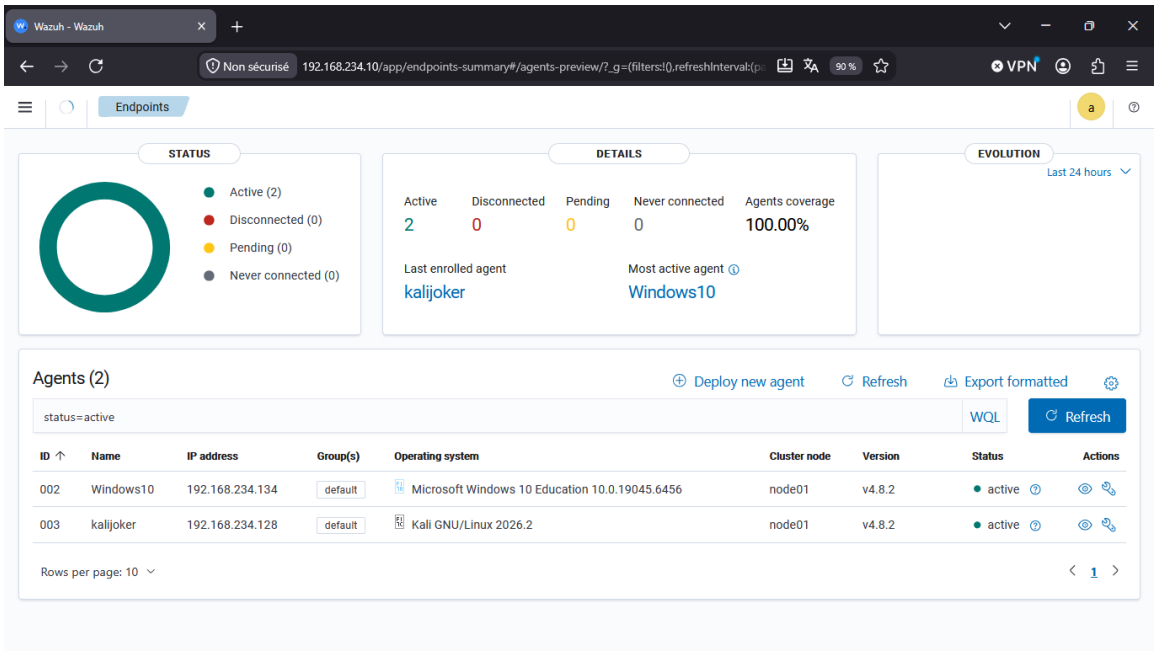


FIGURE 5.3 – Les deux agents (Windows10 et kalijoker) actifs, version 4.8.2, couverture 100 %

Chapitre 6

Journal de bord : problèmes rencontrés et solutions

Ce chapitre est probablement le plus formateur du rapport. Chaque incident est présenté avec son symptôme, sa cause réelle et sa résolution.

Table 6.1 – Journal des incidents du projet

Symptôme	**Cause identifiée**	**Solution appliquée**
VMs injoignables depuis Internet en mode bridged	Borne Wi-Fi refusant les MAC virtuelles	Bascule de tout le labo en NAT (VMnet8)
DNS inaccessible sous Windows	Conséquence du bridged Wi-Fi ; passerelle injoignable	Mode NAT + DHCP VMware
Démarrage Windows bloqué sur « Repairing disk errors »	Arrêts brutaux successifs de la VM	Laisser le chkdsk se terminer, ne jamais interrompre
Agent Linux refusant de démarrer après installation	Fichier de configuration généré par Wazuh 4.14 (balises `journal`, `users` inconnues de la 4.8.2)	Downgrade du paquet puis remplacement du fichier ossec.conf par une configuration propre 4.8.2
Aucune alerte SSH remontée depuis Kali	Service rsyslog inactif : /var/log/auth.log n'existait pas	Installation et activation de rsyslog
Kali injoignable après quelques heures	Bail DHCP manuel expiré ; reprise de l'ancienne IP statique 192.168.3.10 d'un projet antérieur	IP statique 192.168.234.128 figée dans /etc/network/interfaces
Configuration réseau appliquée sur la mauvaise interface	Profil NetworkManager accroché à une interface virtuelle Docker (veth)	Affectation manuelle de l'adresse sur eth0 puis correction du fichier interfaces

6.1 Leçons tirées

Trois enseignements majeurs ressortent de ces incidents. Premièrement, **lire le message d'erreur en entier** : la moitié des solutions étaient écrites noir sur blanc dans les logs (par exemple `Invalid value for element 'log_format'`). Deuxièmement, **vérifier la cohérence des versions** avant toute installation : un agent plus récent que son serveur est une source garantie de dysfonctionnements. Troisièmement, **comprendre le chemin du log** : sans rsyslog, un événement SSH reste enfermé dans le journal systemd et le SIEM devient aveugle.

Chapitre 7

Simulations d'attaques et détection

7.1 Méthodologie

Conformément aux pratiques professionnelles de *validation de détection* (type purple team ou outils BAS), les attaques ont été simulées de manière contrôlée sur le laboratoire. Les alertes produites sont strictement identiques à celles d'une attaque réelle : mêmes logs, mêmes règles, même mappage MITRE.

7.2 Attaque 1 : brute force sur comptes Windows

Six tentatives de connexion réseau avec des mots de passe erronés ont été effectuées depuis la machine Windows 10 :

```
net use \\127.0.0.1\IPC$ /user:admin mauvaispass1
net use \\127.0.0.1\IPC$ /user:admin mauvaispass2
...
```

Chaque tentative génère l'événement Windows 4625, remonté par l'agent et transformé en alerte :

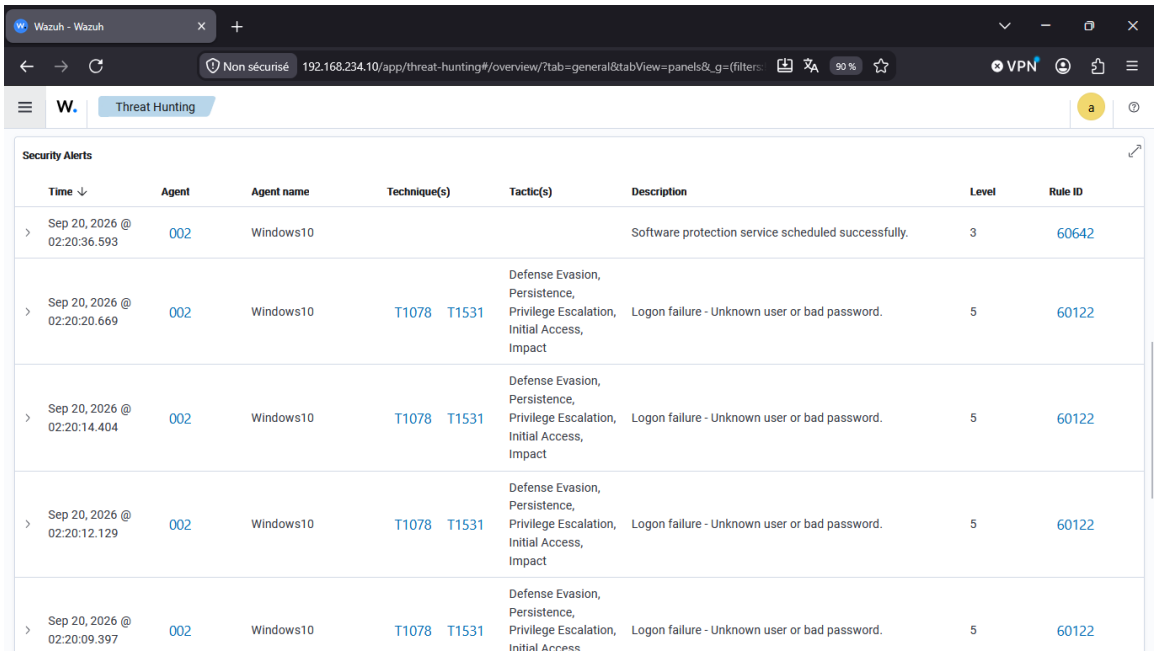


FIGURE 7.1 – Alertes de règle 60122 « Logon failure - Unknown user or bad password » (niveau 5), avec tactiques et techniques MITRE ATT&CK

7.3 Attaque 2 : brute force SSH sur le serveur Kali

Depuis la machine Windows, plusieurs tentatives de connexion SSH ont été réalisées avec un utilisateur inexistant :

```
ssh attaquant@192.168.234.128
# mot de passe erron saisi 6 fois
```

Le serveur Kali a produit les alertes suivantes, dont une de **niveau 10** caractérisant l'attaque :

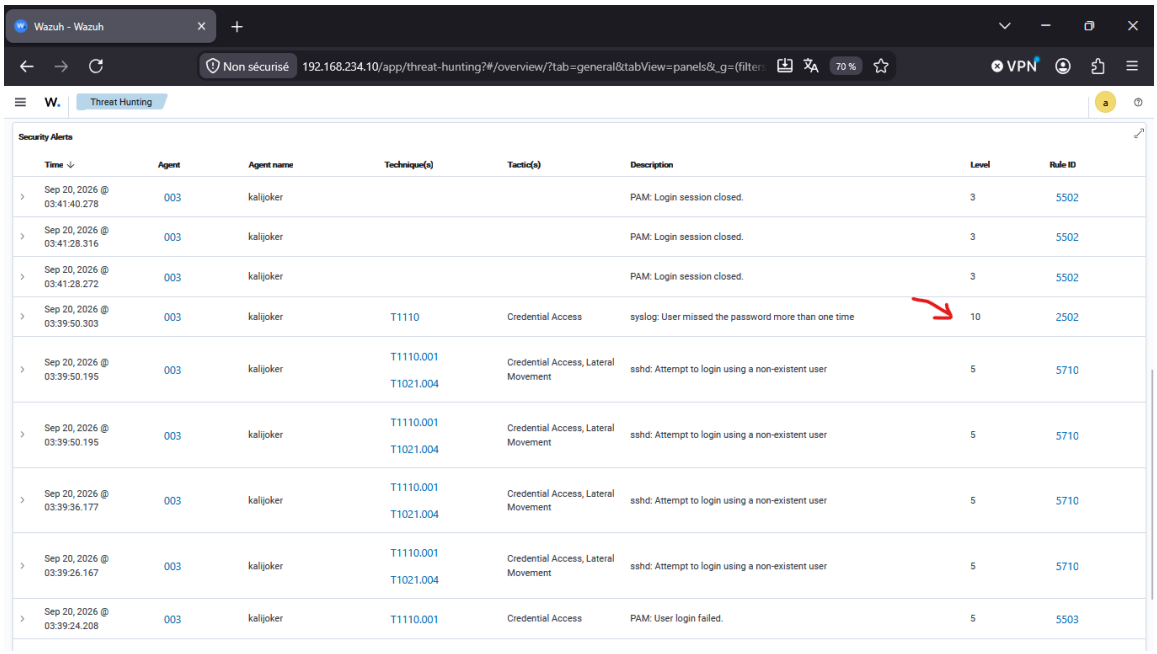


FIGURE 7.2 – Détection de la brute force SSH : règle 2502 niveau 10 (T1110) et règles 5710 (utilisateurs inexistants)

7.4 Lecture des fiches agent

Le dashboard fournit pour chaque agent une fiche détaillée (système d'exploitation, version, état de connexion, modules actifs), utile pour l'inventaire du parc :

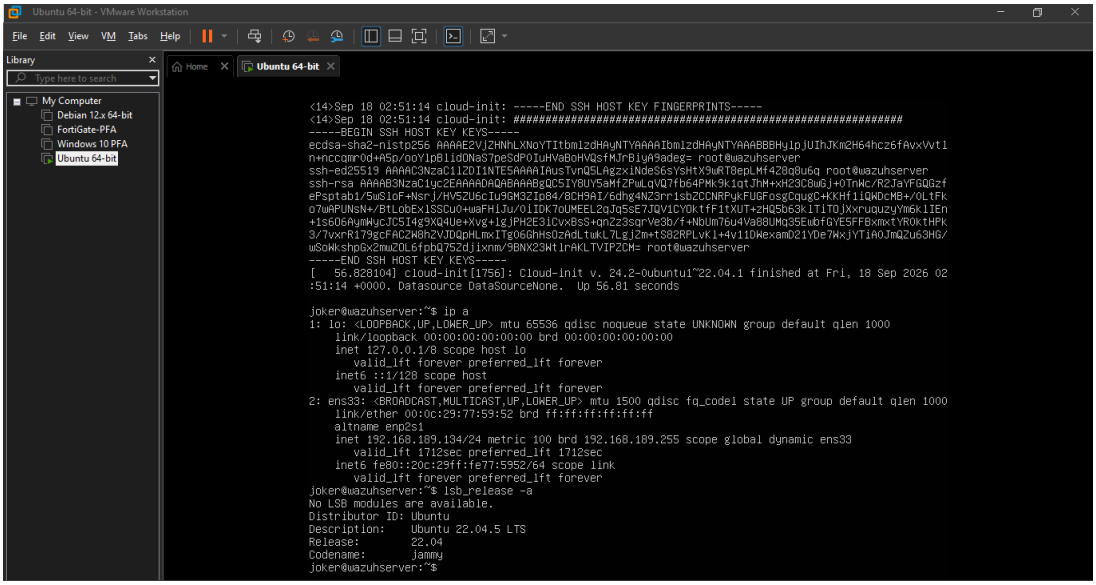


FIGURE 7.3 – Fiche d'information système de l'agent dans le dashboard

Chapitre 8

Analyse des alertes : méthode d'un analyste SOC

Détecter ne suffit pas : il faut qualifier. Voici, appliquée à l'incident SSH, la grille d'analyse qu'utiliserait un analyste SOC de premier niveau.

Table 8.1 – Fiche d'analyse de l'incident « brute force SSH »

Quoi ?	Six échecs d'authentification SSH en moins d'une minute
Qui ?	Source 192.168.234.134 (Windows10) vers cible 192.168.234.128 (kalijoker)
Quand ?	20/09/2026, 03 :39
Détection	Escalade 5503 (niveau 5) puis 5710 (niveau 5) puis 2502 (niveau 10)
Mappage MITRE	T1110 Brute Force, sous-technique T1110.001 Password Guessing, T1021.004 SSH
Phase de la kill chain	Credential Access
Qualification	Attaque confirmée (test contrôlé), aucun faux positif
Réponse recommandée	Blocage de l'IP source, revue du compte visé, durcissement de sshd, surveillance renforcée 24 h

Le passage automatique du niveau 5 au niveau 10 illustre l'intérêt de la corrélation : pris isolément, un échec de connexion est banal ; répété en quelques secondes, il devient une signature d'attaque. C'est exactement le raisonnement qu'un analyste applique quotidiennement devant sa console.

Chapitre 9

Conclusion et perspectives

9.1 Bilan

Ce projet a permis de construire une plateforme SIEM complète et fonctionnelle : un serveur Wazuh 4.8.2, deux agents supervisés couvrant 100 % du parc, et la détection démontrée de deux scénarios d'attaque avec mappage MITRE ATT&CK. Au-delà du résultat technique, c'est la démarche qui a été formatrice : diagnostiquer une panne réseau liée au Wi-Fi, comprendre la chaîne de collecte d'un log Linux, harmoniser des versions logicielles, qualifier une alerte comme un analyste.

9.2 Limites

Le laboratoire reste perfectible : les attaques sont simulées, le serveur est unique (pas de haute disponibilité) et la réponse aux incidents est encore manuelle.

9.3 Perspectives

Trois chantiers prolongeraient naturellement ce travail : l'activation de l'*active response* (blocage automatique de l'attaquant par le pare-feu de l'agent), l'écriture de règles personnalisées de détection, et la comparaison avec un second SIEM du marché (Splunk ou Elastic) afin d'élargir la culture outil. À plus long terme, ce projet constitue une base solide pour préparer des certifications orientées défense telles que CompTIA CySA+ ou BTL1.

Annexe A

Anti-sèche : commandes utiles

Côté serveur (Ubuntu)

```
systemctl status wazuh-manager wazuh-indexer wazuh-dashboard
tail -f /var/ossec/logs/alerts/alerts.json
sudo sed -i 's/^network.host: .*/network.host: 0.0.0.0/' /etc/wazuh-indexer/
    opensearch.yml
```

Côté agent Linux

```
systemctl status wazuh-agent
tail -n 20 /var/ossec/logs/ossec.log | grep -i connected
cat /var/ossec/etc/ossec.conf
```

Côté agent Windows

```
Get-Service WazuhSvc
Get-Content "C:\Program Files (x86)\ossec-agent\ossec.log" -Tail 10
```

Annexe B

Glossaire

SIEM Système de gestion des informations et événements de sécurité.

Agent Programme installé sur une machine supervisée, chargé de collecter et transmettre les logs.

Règle Signature associant un motif de log à un niveau de gravité.

Niveau d'alerte Gravité de 0 à 15 ; au-delà de 10, attaque caractérisée.

MITRE ATT&CK Référentiel international des techniques et tactiques d'attaquants.

Brute force Attaque consistant à essayer massivement des mots de passe.

FIM Surveillance de l'intégrité des fichiers (File Integrity Monitoring).

NAT / Bridged Modes réseau de virtualisation : partage d'IP de l'hôte / connexion directe au réseau physique.

rsyslog Service Linux écrivant les journaux système dans des fichiers tels que /var/log/auth.log.